Role Manifest Spec

The declared-role side of detection: format, examples, change control

1. What a manifest is

A manifest is the declared side of the comparison: what a role is allowed to do. Detection measures behaviour against it. Manifests are YAML, versioned, and signed by the role owner.

2. Fields

Field	Meaning
role, version, owner	Name, integer version (increases on every change), accountable person or team
description	One plain sentence of the role's purpose; also embedded for semantic drift checks
allowed_tools	Tools the role may call
allowed_data_classes / forbidden_data_classes	Data the role may touch / must never touch (forbidden wins)
egress_allowlist	Hosts the role may send data to; anything else is external egress
limits	max_records_per_call, max_bytes_out_per_hour, max_calls_per_minute
requires_approval	Actions that always need a human, with conditions
delegation	Which roles this role may call and the scopes it may pass on
honeypots	Decoy resources no legitimate agent touches; any access is an alert
signature	Ed25519 signature over the canonical manifest, by the owner's key

3. Example

```
role: procurement-agent
version: 3
owner: procurement-platform-team
description: Checks supplier prices and creates purchase requests.
allowed_tools: [supplier_price_api, read_catalog, create_purchase_request]
allowed_data_classes: [supplier, pricing, purchase_request]
forbidden_data_classes: [hr, payroll, finance_ledger]
egress_allowlist: [api.approved-supplier.com, erp.internal]
limits: {max_records_per_call: 200, max_bytes_out_per_hour: 5000000, max_calls_per_minute: 60}
requires_approval:
  - {tool: create_purchase_request, when: "amount > 100000"}
delegation: {may_call: [pricing-analyst-agent], pass_scopes: [read_catalog]}
honeypots: [hr/salaries_2026_FULL.xlsx]
signature: ed25519:...
```

4. Starter roles (define these three first)

Role	Allowed	Forbidden	Egress
procurement-agent	supplier prices, catalog, purchase requests	hr, payroll, finance ledger	approved supplier API, internal ERP
hr-assistant-agent	leave policy, org chart, onboarding docs	payroll amounts, supplier data	internal HRIS only
support-agent	ticket system, knowledge base, customer profile (masked)	hr, finance, source code	internal helpdesk, approved email gateway

5. Validation and change control

- The loader rejects a manifest with a bad signature, a lower or equal version, or an unknown field.
- Planned change (new tool, new task): owner edits the manifest, a second approver signs, CI validates, version increases. The detector starts using it at once and treats the change as legitimate, not drift.
- Unapproved change in behaviour with no manifest change is drift and is scored as such.
- Cold start: a new agent of a known role uses the role manifest and role baseline from its first event.
- Delegation rule: a callee's effective scope is the intersection of its own manifest and every caller in the chain.